Autonomous Post-Quantum Cryptographic Migration

Moving enterprise security from noisy static alert overload to explainable, human-governed remediation powered by LangGraph and NIST FIPS 203/204.

🔍 AST Ingestion

Deterministic parsing of 14 deprecated primitives with line-level accuracy and zero hallucination.

🧠 5-Node Agent

LangGraph state machine with CIA Triad & MTU packet bloat evaluation.

🛡️ Human-in-the-Loop

Physical execution pause via interrupt() and immutable SHA-256 audit chain.

02 The Problem: Shor's Algorithm & HNDL Attacks

CORE CHALLENGE

✴ Asymmetric Collapse (Shor's Algorithm)

Shor's algorithm breaks discrete logarithms and integer factorization in polynomial time. RSA-2048, ECDSA P-256, Ed25519, and Diffie-Hellman will provide zero security.

The Active Threat: Adversaries are executing *Harvest Now, Decrypt Later (HNDL)* today—archiving encrypted enterprise ciphertext to decrypt retrospectively once quantum computers scale.

⚠ SAST Incompetence & Alert Overload

Legacy tools like SonarQube and Bandit flag basic bugs but are blind to post-quantum migration. They produce walls of noisy, un-actionable alerts without patches.

The Danger of Autonomous Agents: Blind LLMs rewrite code with hallucinations, compilation errors, and broken network protocols.

System Architecture: 5-Node LangGraph State Machine

01. Take In Evidence

Node 1: INGEST & Node 2: SCAN

Deterministic Python AST parsing and tokenized Java regex extract 14 deprecated primitives with line-level accuracy and zero hallucination.

02. Investigate & Decide

Node 3: INVESTIGATE

LLM Chain-of-Thought maps findings across the CIA Triad. Computes PQC MTU Packet Bloat and synthesizes NIST FIPS 203/204 patches.

03. Act Safely (HITL)

Node 4: APPROVE & Node 5: FINALISE

LangGraph `interrupt()` gate physically halts graph in memory. Requires authenticated human approval. Records SHA-256 audit chain.

04 The Post-Quantum CIA Triad & MTU Packet Bloat

CYBERSECURITY VALUE

Confidentiality (HNDL)

Mitigates passive decryption of intercepted ciphertext on public networks.

NIST Standard: FIPS 203 ML-KEM-768/1024 lattice key encapsulation.

Integrity (Forgery)

Prevents discrete log quantum forgery of ECDSA & RSA signatures.

NIST Standard: FIPS 204 ML-DSA-65/87 digital signatures.

Availability (MTU Bloat)

Unique Innovation: ML-DSA signatures (3,309 bytes) exceed standard 1500-byte Ethernet MTUs.

Alerts network engineers to potential TCP packet fragmentation and handshake timeouts before deployment.

Human-in-the-Loop & SHA-256 Audit Trail

🔒 Zero-Trust Human Governance

The agent operates under strict read-only constraints. It synthesizes side-by-side diffs (Legacy RSA vs ML-KEM) but cannot write code without human sign-off.

```
# LangGraph interrupt() physically suspends execution
human_decision = interrupt({"status":
"awaiting_review"}) # Unblocked only via
Command(resume=decision)
```

📋 Tamper-Evident SHA-256 Chain

Every event is cryptographically hashed with its ancestor:

```
Hash_n = SHA256(Hash_n-1 + Timestamp + Actor + Action
+ Detail)
```

Guarantees non-repudiation and immutable evidence for SOC2 and NIST SP 800-227 audit compliance.

06 Empirical Benchmark & Conclusion

SOTA VALIDATION

📊 Literature Benchmark (SECRYPT 2025)

- **96.8% AST Precision** (vs 62.4% Classical SAST)
- **< 45 ms Static Scan Throughput**
- **100% PQC Threat Awareness** (NIST FIPS 203/204)
- **Zero Unchecked Autonomous Writes** (HITL Gate)

🚀 Active Deliverables & Roadmap

- Interactive Streamlit Dashboard (Port 8501)
- DevSecOps Headless CI/CD Scanner (`pqc_agent.cli`)
- Interactive Digital Poster Web App
- Next: LLVM/Clang C/C++ AST for embedded IoT systems